Analiza porównawcza mechanizmów uwierzytelniania

Wykonawcy: Kamil Szkarłat, Jakub Szkaradek, Bartłomiej Ząbek, Radosław Chruściński, Wojciech Śliwa, Mikołaj Mierzwa

---

1) Merytoryka i główne założenia projektowe

- Przeprowadzenie analizy porównawczej mechanizmów uwierzytelniania z uwzględnieniem uniwersalności zastosowania, funkcjonalności dla użytkownika końcowego oraz odporności na ataki.
- Analiza zagrożeń związanych z wdrażaniem konkretnych mechanizmów w transakcjach elektronicznych.
- Opracowanie techniki wizualizacji działania poszczególnych analizowanych metod uwierzytelniania.

2) Zakres projektu

- Badanie mechanizmów: hasła jednorazowe, kody SMS, aplikacje uwierzytelniające oraz powiadomienia Push, sprzętowe klucze bezpieczeństwa (standardy FIDO2 / WebAuthn), uwierzytelnianie biometryczne, karty zbliżeniowe i magnetyczne, uwierzytelnianie wieloskładnikowe (MFA – łączące powyższe czynniki)
- Analiza wdrożeń w trzech relacjach biznesowych: B2B, B2C oraz C2C.
- Weryfikacja odporności badanych metod na najczęstsze wektory ataków (phishing, MitM, socjotechnika).
- Przygotowanie zestawienia porównawczego, rekomendacji ochronnych oraz modułu wizualizacyjnego.

3) Cele merytoryczne

- Przegląd najważniejszych metod uwierzytelniania stosowanych w transakcjach elektronicznych (MFA, biometria, klucze sprzętowe, OTP).
- Analiza rozwiązań stosowanych w relacjach B2B (*Business-to-Business*), B2C (*Business-to-Consumer*) oraz C2C (*Consumer-to-Consumer*).
- Porównanie rozwiązań w kontekście funkcjonalności (UX) oraz balansu pomiędzy bezpieczeństwem a wygodą użytkowania.
- Ocena mechanizmów pod kątem podatności i zbadanie odporności na ataki (phishing, socjotechnika, MitM).
- Opracowanie metodyki przeciwdziałania i zapobiegania zidentyfikowanym zagrożeniom.
- Stworzenie raportu podsumowującego analizę oraz wizualizacji działania badanych metod.

4) Źródła informacji

- Normy i standardy bezpieczeństwa: NIST SP 800-63B, ISO/IEC 27001, dyrektywa PSD2 (SCA).
- Dokumentacja techniczna: specyfikacje FIDO Alliance (FIDO2 / WebAuthn) oraz RFC (TOTP/HOTP).
- Publikacje naukowe, raporty branżowe (OWASP, ENISA) oraz studia przypadków dot. ataków na MFA.

5) Planowane efekty

- Raport końcowy zawierający wielokryterialną matrycę porównawczą badanych mechanizmów.
- Zestaw rekomendacji i wytycznych pozwalających ograniczyć ryzyko przejęcia konta.
- Działająca wizualizacja (demo) prezentująca przebieg uwierzytelniania i odporność na ataki.

6) Zebranie odpowiednich materiałów źródłowych

- Przegląd norm i regulacji branżowych określających wymogi silnego uwierzytelniania (PSD2, NIST).
- Research publikacji akademickich dotyczących ergonomii (UX) i bezpieczeństwa metod weryfikacji tożsamości.
- Analiza udokumentowanych incydentów przełamania zabezpieczeń.

7) Określenie narzędzi koniecznych do wykonania projektu

- **Część analityczna:** specyfikacje protokołów (FIDO2, TOTP), narzędzia deweloperskie przeglądarek (DevTools / WebAuthn Virtual Authenticator).
- **Część wizualizacyjna:** technologie webowe (HTML5, CSS, JavaScript) lub Python do budowy prostego modułu demonstracyjnego.
- **Dokumentacja i obliczenia:** środowisko Overleaf (LaTeX), arkusze kalkulacyjne do matrycy porównawczej.

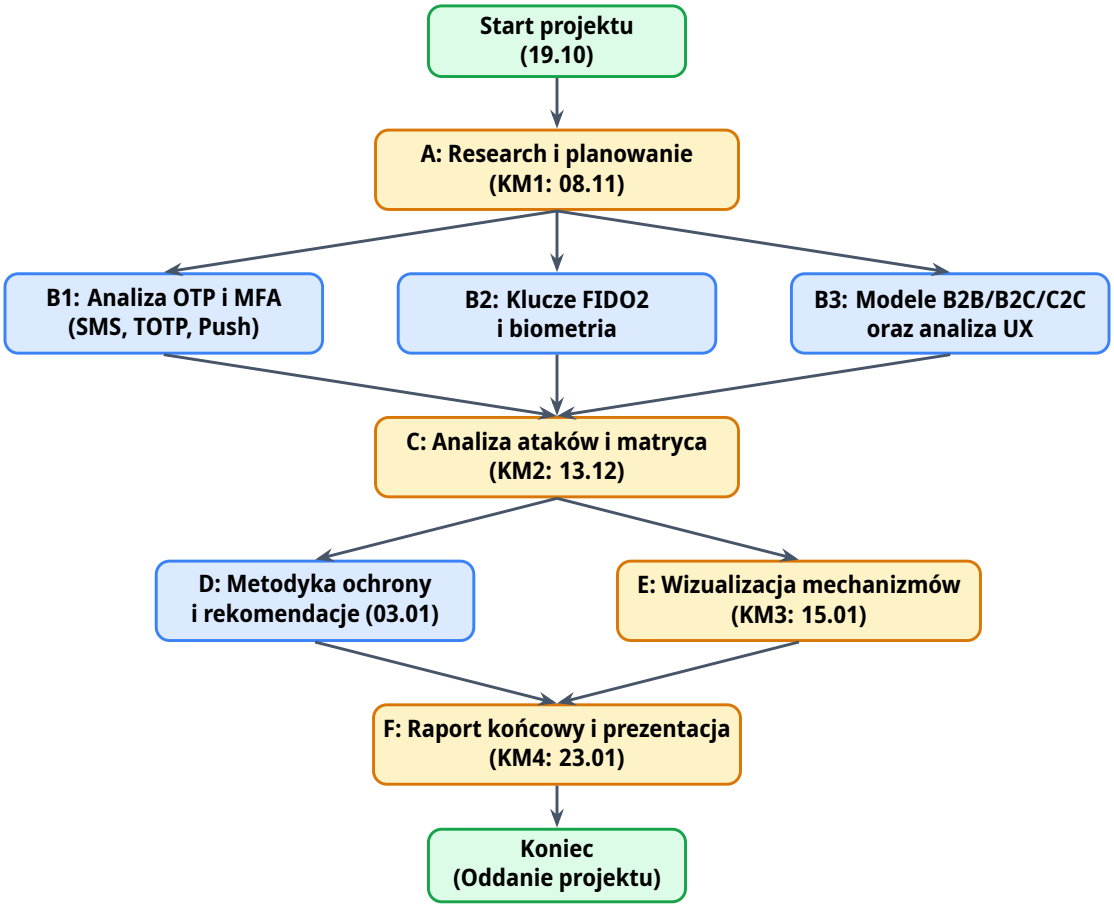
8) Określenie metodyki realizacji prac

- **Etap 1 – Research i planowanie:** zebranie literatury, podział zadań i zdefiniowanie kryteriów oceny.
- **Etap 2 – Analiza mechanizmów:** równoległe badanie mechanizmów uwierzytelniania oraz modeli B2B/B2C/C2C.
- **Etap 3 – Badanie podatności i matryca:** ocena odporności na ataki (MitM, phishing) i zestawienie wyników w tabeli.
- **Etap 4 – Ochrona, wizualizacja i raport:** opracowanie metod obrony, budowa wizualizacji i redakcja raportu.

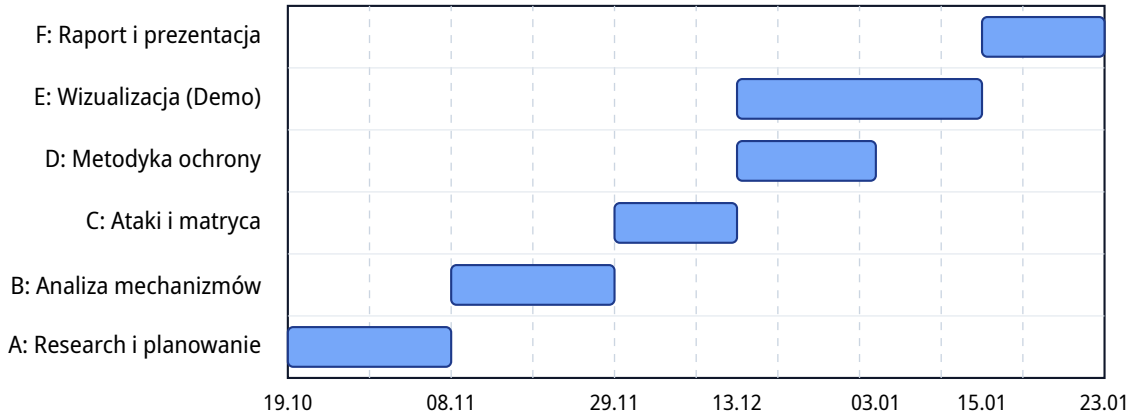
9) Zadania i zależności między nimi (Wykres PERT)

Projekt podzielono na 6 głównych zadań (**A–F**), w tym trzy równoległe ścieżki analityczne (**B1–B3**):

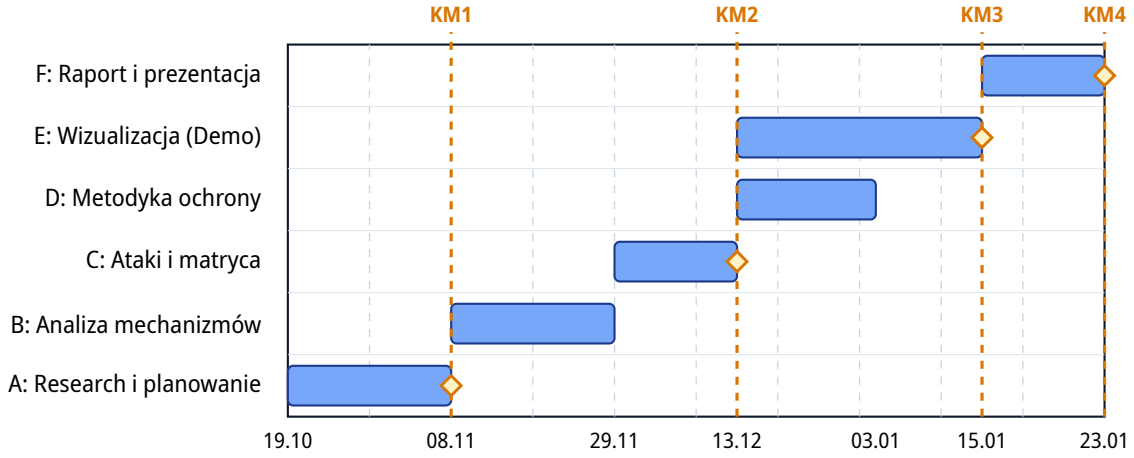
- **A:** Research literatury i planowanie projektu (19.10 – 08.11)
- **B:** Analiza mechanizmów: **B1** (OTP i MFA), **B2** (Klucze FIDO2 i biometria), **B3** (B2B/B2C/C2C i UX) (09.11 – 29.11)
- **C:** Analiza podatności na ataki i budowa matrycy porównawczej (30.11 – 13.12)
- **D:** Opracowanie metodyki przeciwdziałania zagrożeniom (14.12 – 03.01)
- **E:** Przygotowanie wizualizacji działania mechanizmów (14.12 – 15.01)
- **F:** Opracowanie raportu końcowego i prezentacji (16.01 – 23.01)



10) Wstępny harmonogram (wykres Gantta)



11) "Kamienie milowe" (z zaznaczeniem na wykresie Gantta)



Wykaz kamieni milowych:

- **KM1 (08.11):** Zatwierdzenie bazy źródłowej, założeń oraz szczegółowego planu projektu.
- **KM2 (13.12):** Zakończenie analizy porównawczej mechanizmów oraz opracowanie matrycy zagrożeń.
- **KM3 (15.01):** Gotowy prototyp wizualizacji działania mechanizmów oraz wersja robocza raportu.
- **KM4 (23.01):** Finalizacja raportu końcowego, przygotowanie prezentacji i zamknięcie projektu.

12) Określenie metod współpracy i komunikacji

- **a) Narzędzia do pracy grupowej:** współdzielenie zasobów na dysku OneDrive / Google Drive (dokumentacja, raport), repozytorium GitHub (kod wizualizacji), Overleaf (skład w LaTeX).
- **b) Komunikacja między członkami zespołu:** bieżąca komunikacja oraz cotygodniowe spotkania online na platformie Discord.
- **c) Osoba kontaktowa / koordynator:** Kamil Szkarłat.
- **d) Sposoby weryfikacji realizacji zadań projektowych:**
  - Ewaluacja wartości merytorycznej analizy podczas konsultacji z prowadzącym (KM1–KM4).
  - Przeglądy postępu prac podczas cotygodniowych spotkań zespołu
  - Wzajemna recenzja opracowanych rozdziałów przez członków zespołu (*peer-review*).

13) Sposób przedstawienia wyniku końcowego

- **Raport końcowy:** dokument opisujący wyniki analizy porównawczej, matrycę zagrożeń i metodykę ochrony.
- **Prezentacja:** wystąpienie multimedialne przedstawiające podejmowaną tematykę oraz wnioski z analizy.
- **Wizualizacja:** demonstracja działania analizowanych mechanizmów uwierzytelniania.

Materiały źródłowe:

- NIST Special Publication 800-63B (*Digital Identity Guidelines: Authentication and Lifecycle Management*).
- Specyfikacje techniczne FIDO Alliance (FIDO2 / WebAuthn) oraz dyrektywa PSD2 (SCA).
- Baza wiedzy OWASP (*Authentication Cheat Sheet*) oraz normy ISO/IEC 27001 / 27002.